Capstone Project SCALA-Guard: An Intelligent Open-Source Package Security Analysis Platform with AI-Assisted Remediation A full-stack threat intelligence platform for detecting and resolving malicious NPM and PyPI packages using behavioral analysis and LLM-powered remediation Core Modules ModuleWhat it DoesPackage Ingestion EngineUpload or fetch packages from NPM/PyPI registry by name/versionBehavioral Analysis PipelineSystem call tracing + network traffic capture in an isolated sandboxRisk Scoring DashboardMalicious/Benign probability (%) with confidence band per packageDeepSeek Remediation EngineAI-generated fix suggestions, safe alternative packages, CVE mappingBatch Audit ModeScan entire requirements.txt or package.json in one submission Research Contributions Hybrid Feature Fusion — combine syscall sequences + network egress patterns into a unified feature vector for higher classification accuracy Explainability Layer — highlight which syscalls or network events drove the malicious score (SHAP values or rule highlights) LLM Remediation Quality Evaluation — benchmark DeepSeek suggestions against known CVE patches as a secondary research output Suggested Capstone Title SCALA-Guard: Behavioral Package Threat Intelligence with LLM-Assisted Remediation for Open-Source Ecosystems Tech Stack Suggestion LayerStackFrontendReact + TailwindBackendFastAPI (Python)SandboxDocker + strace / tcpdumpML ModelScikit-learn (RF / XGBoost)LLMDeepSeek APIStoragePostgreSQL + Redis (queue) What Makes It Capstone-Worthy Combines cybersecurity + ML + LLM — three active research intersections Has a working prototype (your existing site) as the baseline — strong for evaluation chapters DeepSeek integration elevates it from a detector to an actionable security tool Batch scanning of requirements.txt / package.json has real-world CI/CD deployment potential — strong future work angle

what was prompt or question from user?

Mar 30

There was no question or prompt from the user in this conversation — this is actually the **very first message**, and it consists entirely of a detailed Capstone Project proposal document describing **SCALA-Guard**.

The user simply shared/pasted the project outline without asking anything specific. There was no explicit question, instruction, or request attached to it.

ei projecte ki kaj korbo bujao

Mar 30

এই project-এ তুমি মূলত **একটা Security Platform** বানাবে যেটা দিয়ে **NPM আর PyPI package-এর মধ্যে malicious/ভাইরাস কিছু আছে কিনা সেটা detect করা যাবে।**

সহজ ভাষায় বলি —

ধরো তুমি একটা Python project করছো, আর `requirements.txt`-এ অনেক package আছে। এখন সেই কোনো package-এ **malware, data stealer, বা backdoor** থাকতে পারে — তুমি জানো না।

SCALA-Guard এই কাজটা করবে — package গুলো scan করে বলবে এটা **safe নাকি dangerous।**

৫টা মূল কাজ —

১. Package নিয়ে আসা NPM বা PyPI থেকে package download করবে বা তুমি upload করবে।

২. Sandbox-এ চালানো Package-টাকে একটা isolated Docker container-এ run করবে — সে কী কী system call করছে, কোন network-এ connect করছে সেটা record করবে।

৩. ML দিয়ে বিশ্লেষণ সেই recorded data দেখে ML model বলবে — এটা **Malicious নাকি Benign**, কত % সম্ভাবনা।

৪. AI দিয়ে সমাধান যদি dangerous হয়, **DeepSeek AI** বলবে — কী করবে, কোন safe alternative আছে, কোন CVE vulnerability আছে।

৫. Batch Scan পুরো `requirements.txt` বা `package.json` একসাথে scan করা যাবে।

এককথায় —

> "Package দাও → Sandbox-এ চালাও → ML দিয়ে threat detect করো → AI দিয়ে fix বলো"

এটা **Cybersecurity + Machine Learning + AI** — তিনটা জিনিস একসাথে, তাই Capstone-এর জন্য অনেক strong project।

কোন part নিয়ে বিস্তারিত জানতে চাও?

supervisor bollo ei dia ekta dashboard/website create korte ki korbo?

7:26 AM

তোমার supervisor বলেছে এই project দিয়ে একটা **Dashboard/Website** বানাতে। চলো step-by-step বলি কী কী করতে হবে —

যা যা বানাতে হবে (Pages/Features)

১. Home / Landing Page

- Project এর overview
- "Scan a Package" button

২. Package Scanner Page

- Package name + version input (NPM/PyPI)
- File upload (requirements.txt / package.json)

- Scan button → result দেখাবে

৩. Risk Score Dashboard

- Malicious / Benign % দেখাবে
- Chart/graph দিয়ে visual দেখাবে
- কোন syscall বা network activity suspicious ছিল সেটা highlight করবে

৪. AI Remediation Page

- Dangerous হলে DeepSeek AI এর fix suggestion দেখাবে
- Safe alternative package suggest করবে
- CVE list দেখাবে

৫. Batch Audit Page

- পুরো requirements.txt upload করলে সব package একসাথে scan হবে
- Table আকারে result দেখাবে

Tech Stack কী ব্যবহার করবে

Part	Technology
Frontend	React + Tailwind CSS
Backend	FastAPI (Python)
Database	PostgreSQL
ML Model	Scikit-learn
AI	DeepSeek API
Sandbox	Docker

কোথা থেকে শুরু করবে?

সহজ ভাবে শুরু করতে চাইলে এই order-এ করো —

```
১. Frontend UI বানাও (React)
২. Backend API বানাও (FastAPI)
৩. ML Model connect করো
৪. DeepSeek AI connect করো
৫. Docker sandbox add করো
```

তুমি কি চাও আমি এখনই **Frontend Dashboard-এর একটা prototype** বানিয়ে দিই দেখার জন্য? 🚀

accha ei project er website e kotai konta use kora hobe llm, Cybersecurity and machine learning?

7:31 AM

চমৎকার প্রশ্ন! চলো একদম clearly বলি — website-এর **কোন জায়গায় কোন technology কাজ করবে:**

🔵 Machine Learning — কোথায় ব্যবহার হবে?

Risk Score Dashboard-এ

- Package sandbox-এ run করার পর যে data পাওয়া যাবে (syscall, network activity) — সেটা ML model-এ দেওয়া হবে
- ML model (Random Forest / XGBoost) বলবে — এই package **Malicious নাকি Benign**
- কত % probability সেটাও দেখাবে
- **SHAP values** দিয়ে বলবে — কোন syscall বা network event দেখে এই সিদ্ধান্ত নিয়েছে

```
Input → syscall sequences + network traffic data
Output → Malicious (87%) / Benign (13%)
```

🔴 Cybersecurity — কোথায় ব্যবহার হবে?

Sandbox / Behavioral Analysis-এ

- Package-টাকে **Docker container**-এ isolated করে run করা হবে
- `strace` দিয়ে system call trace করবে
- `tcpdump` দিয়ে network traffic capture করবে
- CVE database থেকে known vulnerability check করবে
- এই পুরো কাজটাই cybersecurity part

```
Package আসলো → Docker-এ চললো →
strace দিয়ে syscall record → tcpdump দিয়ে network record
```

🟢 LLM (DeepSeek AI) — কোথায় ব্যবহার হবে?

AI Remediation Page-এ

- ML যখন বলবে "এটা Malicious" — তখন DeepSeek-কে জিজ্ঞেস করবে
- DeepSeek বলবে —
    - এই package-এর কী সমস্যা
    - কোন **safe alternative** ব্যবহার করবে
    - কোন **CVE patch** apply করবে
    - Code-এ কী fix করতে হবে

```
ML বললো "Malicious" → DeepSeek-কে পাঠাও →
AI বললো "এর বদলে X ব্যবহার করো, এই CVE fix করো"
```

একসাথে দেখলে —

```
Package Input
      ↓
[Cybersecurity] → Docker Sandbox → syscall + network capture
      ↓
[Machine Learning] → Risk Score → Malicious/Benign %
      ↓
[LLM - DeepSeek] → Fix Suggestion + Safe Alternative + CVE
      ↓
Dashboard-এ দেখাও
```

সহজ কথায় —

- **Cybersecurity** = data সংগ্রহ করে (sandbox)
- **ML** = সেই data দেখে সিদ্ধান্ত নেয়
- **LLM** = সিদ্ধান্তের পর সমাধান দেয়

তিনটা একটার পর একটা কাজ করে — **chain এর মতো!** ⛓️

কোন part নিয়ে আরো details জানতে চাও?

sob part nia

7:34 AM

ঠিক আছে! চলো **সব part নিয়ে বিস্তারিত** বলি — একদম শুরু থেকে শেষ পর্যন্ত।

---

১. 🔴 Cybersecurity Part — Sandbox & Behavioral Analysis

কী করবে?

Package-টা **real environment-এ না চালিয়ে** একটা isolated জায়গায় চালাবে — যাতে যদি malware থাকে, সেটা তোমার computer-এর ক্ষতি করতে না পারে।

Step by Step —

```
১. User package দিলো (npm install xyz / pip install xyz)
২. Docker container চালু হলো (isolated environment)
৩. Package সেই container-এ install + run হলো
৪. strace দিয়ে সব system call record হলো
   যেমন: file open, network connect, process spawn
৫. tcpdump দিয়ে network traffic capture হলো
   যেমন: কোন IP-তে data পাঠাচ্ছে, কোন domain-এ connect করছে
৬. সব data collect করে ML-এ পাঠানো হলো
```

Suspicious জিনিস যা detect হবে —

- অজানা server-এ data পাঠাচ্ছে কিনা **(data exfiltration)**
- `/etc/passwd` বা sensitive file access করছে কিনা
- নিজে নিজে অন্য process চালু করছে কিনা
- Crypto mining করছে কিনা

Website-এ দেখাবে —

```
📦 Package: malicious-pkg v1.0.2
🔍 Syscalls detected: 847
🌐 Network connections: 3 external IPs
⚠️ Suspicious: Accessed /etc/passwd, Connected to 185.x.x.x
```

---

২. 🔵 Machine Learning Part — Risk Scoring

কী করবে?

Cybersecurity part যে data collect করলো — সেটা দেখে **ML model সিদ্ধান্ত নেবে** এটা malicious নাকি safe।

Feature বানানো হবে —

```
Syscall data থেকে:
- কতবার file_open হয়েছে
- কতবার network_connect হয়েছে
- কোন কোন sensitive syscall হয়েছে
- syscall sequence pattern

Network data থেকে:
- কতটা data বাইরে গেছে
- কোন port ব্যবহার হয়েছে
- known malicious IP/domain কিনা
```

Model Training —

```
Dataset: আগের known malicious + benign package গুলো দিয়ে train করবে
Algorithm: Random Forest + XGBoost
Output: Malicious probability %
```

SHAP Explainability —

```
শুধু "Malicious 87%" বললে হবে না —
SHAP বলবে:
"network_connect syscall সবচেয়ে বেশি suspicious ছিল"
"185.x.x.x IP-তে connection দেখে score বাড়লো"
```

Website-এ দেখাবে —

```
🎯 Risk Score: 87% Malicious
📊 Confidence Band: 82% - 91%

Top Suspicious Factors:
🔴 External network connection (+34%)
🔴 /etc/passwd access (+28%)
🟡 High syscall frequency (+15%)
```

---

৩. 🟢 LLM Part — DeepSeek AI Remediation

কী করবে?

ML যখন বলবে "এটা Malicious" — তখন **DeepSeek AI** সমাধান দেবে।

DeepSeek-কে যা পাঠানো হবে —

```
"Package 'malicious-pkg' এ এই এই suspicious activity পাওয়া গেছে:
- /etc/passwd access করেছে
- 185.x.x.x এ data পাঠিয়েছে
- Risk score: 87%
এর safe alternative কী? CVE আছে কিনা? Fix কী?"
```

DeepSeek যা return করবে —

```
১. কেন এটা dangerous — plain English-এ
২. Safe alternative package suggest
   যেমন: "malicious-pkg এর বদলে safe-pkg v2.1 ব্যবহার করো"
৩. CVE number যদি থাকে
   যেমন: CVE-2024-1234 — এই vulnerability আছে
৪. Code fix suggestion
   যেমন: requirements.txt থেকে এটা সরিয়ে এটা দাও
```

Website-এ দেখাবে —

```
🤖 AI Remediation Report

⚠️ Problem: This package exfiltrates system credentials

✅ Safe Alternative: legitimate-pkg v3.2.1

🔗 CVE: CVE-2024-5678
   Severity: CRITICAL

💡 Fix:
   Remove: malicious-pkg==1.0.2
   Add: legitimate-pkg==3.2.1
```

---

৪. পুরো Flow একসাথে —

```
👤 User
   ↓ package name দিলো / requirements.txt upload করলো

🐳 Docker Sandbox (Cybersecurity)
   ↓ package run করলো
   ↓ syscall + network data collect করলো

🤖 ML Model (Machine Learning)
   ↓ data analyze করলো
   ↓ Risk Score দিলো: 87% Malicious
   ↓ SHAP দিয়ে কারণ বললো

🧠 DeepSeek AI (LLM)
   ↓ fix suggestion দিলো
   ↓ safe alternative বললো
   ↓ CVE mapping করলো

📊 Dashboard
   সব result একসাথে দেখালো
```

---

৫. Website এর Pages Summary —

Page	কী দেখাবে	কোন Technology
Home	Overview + Scan button	Frontend only
Scanner	Package input / file upload	Backend + Cybersecurity
Risk Dashboard	Score + Chart + SHAP	ML
AI Remediation	Fix + CVE + Alternative	LLM
Batch Audit	requirements.txt scan table	সব কিছু একসাথে
History	আগের scan results	PostgreSQL